

# 암호화 지침



주식회사 모인

개정 이력

[illegible]

# 암호화 지침

소관부서 : 정보보안팀

## 제1장 총칙

**제1조(목적)** 이 지침은 주식회사 모인(이하 “회사”라 한다)의 암호화 사용에 관한 사항을 규정하는 정책시행 문서로서 안전한 암호화 관리를 통해 중요정보의 유출 및 노출에 대한 안전성을 확보하기 위한 기준으로써 활용함을 그 목적으로 한다.

**제2조(적용 대상)** 이 지침은 회사에 적용하고 있는 암호화 프로그램 및 암호화키 관리가 적용되어야 하는 데이터 및 시스템을 그 적용범위로 한다.

**제3조(용어의 정의)** 이 지침은 다음 용어 정의를 따른다.

1. “암호화”란 중요한 정보의 보안을 유지하기 위해 그 정보를 특정한 규칙에 따라 변형하여 저장함으로써 해독 방법을 모르는 사람은 그 정보의 내용을 알아볼 수 없도록 하는 것을 의미한다.
2. “복호화”란 암호화된 문장으로부터 원래의 정보를 복구하는 것을 의미한다.
3. “암호화 알고리즘”이란 이해 가능한 정보를 키라고 부르는 문자열과 결합시켜 인식 불가능한 암호문을 만들어 내는 수학적인 함수로서 하나 이상의 비밀 매개 변수를 사용하여 데이터의 정보 내용을 해독할 수 없도록 변환하거나 그렇게 변화된 내용을 다시 원문으로 환원시키기 위해 데이터를 변형시키는 알고리즘을 의미한다.
4. “암호화 프로그램”이란 일정한 형태의 정보를 암호화하기 위한 순차적인 기능을 수행하는 프로그램을 의미한다.
5. “암호화키”란 암호화 및 복호화를 수행하기 위해 암호화 기법 및 프로그램에서 사용하는 키를 의미한다
6. “개인식별정보”란 살아있는 개인에 관한 정보로 개인인 특정 정보주체를 식별할 수 있는 정보를 의미한다.
7. “고유식별정보”란 개인을 고유하게 구별하기 위하여 부여된 식별정보로 주민등록번호, 외국인등록번호, 운전면허번호, 여권번호를 의미한다.
8. “CI(연계정보: Connecting Information)”란 본인확인기관에서 부여하는 개인식별정보로 특정개인의 식별을 위한 고유한 범용 Key값이며 주민등록번호를 Hash화하여 생성한 88Byte의 문자열을 의미한다.

## 제2장 역할 및 책임

### 제4조(정보보호최고책임자)

- 1 정보보호최고책임자(이하 “CISO”라 한다)는 암호화 프로그램 및 암호화키에 대한 보안통제 사항을 규정하고, 정책의 이행을 위하여 필요한 자원을 지원할 책임을 갖는다.
- 2 CISO는 암호화키에 대하여 전담 담당자를 지정하고, 암호화 관련 업무 수행에 대한 활동내역을 검토하여야 한다.

### 제5조(암호화키 관리 담당자)

- 1 암호화키 관리 담당자는 데이터를 암호·복호화하기 위하여 사용되는 암호화키를 안전하게 보관할 책임을 갖는다.

- 2 암호화키 관리 담당자는 암호화키에 대하여 주입·운용·갱신·폐기에 대한 절차에 따라 안전하게 관리하고, 그 내역을 기록하여야 한다.

### 제3장 암호 정책

#### 제6조(암호화 대상 및 방식)

- 1 회사는 법적 요구사항, 처리정보 민감도 및 중요도에 따라 다음 각 호의 중요정보를 암호화 대상으로 선정한다.
  - 1) 개인식별정보: 고유식별정보(주민등록번호, 여권번호, 외국인등록번호, 운전면허번호), 국내 거소신고번호, CI
  - 2) 바이오정보: 지문, 홍채, 얼굴, 정맥, 음성, 필적 등 개인을 식별할 수 있는 신체적 또는 행동적 특징에 관한 정보와 그로부터 가공되거나 생성된 정보
  - 3) 인증정보: 로그인 PIN/비밀번호, 카드 비밀번호, 계좌 비밀번호
  - 4) 중요 금융정보: 카드번호(신용/직불)
  - 5) 그 외 유·노출을 고려하여 CISO가 필요하다고 인정하는 중요정보
- 2 제1항에 따른 암호화 대상 별로 저장 및 전송 시 [별표]에 따라 암호화 정책을 수립하여 적용한다. 다만, 암호화 알고리즘에 대해서는 [별표]에 따라 적용하기 어려운 경우에는 제7조에 따라 신뢰할 수 있는 다른 알고리즘을 적용할 수 있다.

#### 제7조(암호화 방식과 알고리즘 강도)

- 1 회사는 암호화 알고리즘에 대해 ‘금융보안원’ 및 ‘한국인터넷진흥원(KISA)’ 등 신뢰할 수 있는 기관에서 권고하는 기준을 고려하여 선정하고, 권고하는 기준이 변경될 경우 이를 적극적으로 반영한다.
- 2 데이터의 기밀성을 보장하기 위한 암호화 알고리즘은 다음 각 호와 같다.
  - 1) 양방향 암호화: AES256(CBC모드), AES256(GCM모드) 등
  - 2) 단방향 암호화: SHA256, SHA256+ SALT, SHA512, SHA512+ SALT
- 3 데이터의 무결성을 검증하기 위한 암호화 알고리즘은 SHA-256을 표준(SHA-512 권고)으로 사용하며, 다음 각 호와 같이 해시 함수를 구현할 수 있다.
  - 1) MDC(Message Digest Code): 키를 사용하지 않는 일반적인 해시 함수
  - 2) HMAC(Hash-based Message Authentication Code): 보내는 쪽과 받는 쪽이 HMAC에 사용할 키를 교환, 키와 메시지를 결합하여 MAC을 추출
- 4 전자서명, 키교환 등에 사용되는 비대칭키 암호화 알고리즘은 RSA 또는 ECC를 사용하며, RSA의 경우에는 2048 bit 키 이상을 사용한다.

#### 제8조(중요정보 저장 시 암호화)

- 1 회사는 이용자 및 내부 사용자의 다음 각 호의 인증정보에 대해 저장 시 일방향 암호화를 적용하여야 한다.
  - 1) 로그인 PIN/비밀번호
  - 2) 카드 비밀번호
  - 3) 계좌 비밀번호
  - 4) 시스템간 통신용 비밀번호
  - 5) 그 외 인증에 필요한 비밀번호
- 2 회사는 다음 각 호에 해당하는 중요정보는 저장 시 양방향 암호화를 적용하여야 한다.
  - 1) 고유식별정보(주민등록번호, 외국인등록번호, 운전면허번호, 여권번호)
  - 2) 국내거소신고번호

- 3) CI
  - 4) 바이오 정보
  - 5) 카드번호
  - 6) 위치정보
- 3 제1항 제4호에 대해서는 일방향 암호화 적용이 어려운 경우 양방향 암호 알고리즘을 이용하여 암호화를 고려할 수 있다.
  - 4 회사는 인터넷 구간 및 인터넷 구간과 내부망의 중간지점(DMZ)에 이용자 정보 등 주요 정보를 저장 및 관리할 수 없으며, 거래로그를 관리하기 위한 경우에는 반드시 암호화하여 저장·관리하여야 한다.
  - 5 회사는 법률에서 정한 대상 이외의 개인정보(휴대폰 번호, 이메일 등), 기밀정보, 영업비밀과 같은 중요정보에 대해서도 저장 시 암호화를 고려하여야 한다.

#### 제9조(중요정보 송·수신 시 암호화)

- 1 회사는 내·외부 정보통신망을 통해 고객과 서버구간에서 중요정보를 송·수신할 경우에는 다음 각 호의 내용 중 하나의 기능을 적용하여 보안서버를 구축하여야 한다.
  - 1) 웹서버에 SSL 인증서를 설치하여 전송하는 정보를 암호화 송·수신
  - 2) 웹서버에 암호화 응용프로그램을 설치하여 전송하는 정보를 암호화하여 송·수신
- 2 제1항에 따른 내부망 내에서 송·수신되는 고유식별정보 및 개인(신용)정보는 업무상 필요할 경우 암호화 대상에서 제외할 수 있으나, 비밀번호와 바이오정보는 반드시 암호화하여야 한다.
- 3 회사는 대외기관, 수탁사 및 업무 제휴사 등 외부기관과 정보통신망을 통해 중요정보를 송·수신할 경우 VPN 등을 통한 암호화 통신 채널을 구축하여야 한다.

### 제4장 암호화 프로그램 및 암호화키 관리

#### 제10조(암호화 프로그램 관리)

- 1 회사는 암호화 프로그램에 대한 비인가자의 접근을 통제하여야 한다.
- 2 회사는 암호화 프로그램의 소스에 대해 IC카드 등의 보조저장매체를 이용하여 별도로 보관하고, 서버, 개발자 PC 등에 저장을 금지하도록 통제한다.
- 3 회사는 암호화 프로그램의 소스가 복사된 보조저장매체에 대하여 내화 금고 등 안전한 장소에 보관하여야 한다.
- 4 회사는 암호화 프로그램 관련 설계서도 암호화 프로그램과 동일한 보안 수준으로 관리하여야 한다.

#### 제11조(암호화키 관리)

- 1 암호화키 관리 담당자는 암호화키의 노출을 최소화하기 위해 비인가자 접근이 통제된 별도의 안전한 장소에 보관하고, 다음 각 호의 사항을 준수하여야 한다.
  - 1) 테스트 시스템 및 운영시스템에서 사용하는 암호화키는 서로 다르게 적용
  - 2) 암호화키에 대한 접근권한 부여는 최소화 및 접근에 대한 모니터링을 실시
  - 3) 보조저장매체에 보관된 키는 임의로 타 매체 저장 및 복사본 생성 금지
  - 4) 암호화키는 암호화 프로그램에서 관독이 가능한 상태로 삽입 금지
  - 5) 소스코드에 하드코딩 방식의 암호화키 기록 금지
- 2 외부업체가 개발한 암호화 프로그램을 사용하는 경우 암호화키를 외부업체로부터 인수하는 즉시 변경하여야 한다.
- 3 암호화키를 암호화하여 관리하는 경우, 키 암호화키의 암호 강도는 데이터 암호화키 이상으로 구성하여야 한다.
- 4 암호화키 관리 담당자는 안전한 암호화키 관리를 위해 암호화 키 관리에 대한 책임이 명시되어 있는 별도의 보안서약서에 서명을 하여야 한다.

#### **제12조(암호화키 생성)**

- 1 암호화키에 대한 생성은 CISO의 승인을 득하여야 하며, 키관리솔루션(KMS)을 통해 암호화키를 생성하고, 다음 각 호의 사항이 기록되도록 관리하여야 한다.
  - 1) 암호화키 일련번호
  - 2) 키생성 일시
  - 3) 키사용 용도
  - 4) 신청자 정보
  - 5) 승인자 정보 등
- 2 생성된 암호화키는 제11조에 따라 안전하게 관리한다.

#### **제13조(암호화키 배포)**

- 1 암호화키에 대한 배포는 사전 지정된 담당자를 통해서만 허용될 수 있다.
- 2 암호화키를 정보통신망을 통해 전송하는 경우 암호화키가 노출되지 않도록 안전한 방법으로 전송하여야 한다.

#### **제14조(암호화키 변경)**

- 1 암호화키에 대한 변경은 암호화키 변경 시 비용, 회사의 정보자산 및 업무 중요도 등을 고려하여 변경할 수 있다.
- 2 암호화키 유출, 암호화 프로그램의 해킹이 의심되는 경우에는 즉시 암호화키를 변경하여야 한다.
- 3 암호화키의 변경(갱신) 등의 이유로 암호화키를 확인할 필요가 있는 경우 다음 각 호의 사항을 기록하여 CISO의 승인을 득하여야 하며, 암호화키 관리 담당자의 협조 하에 키관리솔루션(KMS)에서 암호화키를 확인한다.
  - 1) 암호화키 일련번호
  - 2) 신청일자
  - 3) 키열람 사유
  - 4) 신청자 정보
  - 5) 승인자 정보 등

#### **제15조(암호화키 폐기)**

- 1 암호화키를 다음 각 호에 따라 더 이상 사용할 수 없을 경우에는 암호화키 관리 담당자가 주기적으로 폐기하여야 한다.
  - 1) 암호화키의 도난, 분실, 유출 등의 상황이 발생한 경우
  - 2) 암호화키의 유출 및 키의 훼손이 의심될 경우
- 2 암호화키 관리 담당자는 폐기에정 암호화키에 대해 키관리솔루션(KMS)에서 삭제하고, 다음 각 호의 사항이 기록되도록 관리하여야 한다.
  - 1) 암호화키 일련번호
  - 2) 키폐기 사유
  - 3) 폐기일자
  - 4) 폐기담당자 등

**제16조(암호화키 복구)** 암호화키 손상 등으로 인해 복구가 필요한 경우 제11조제1항에 따른 별도의 안전한 장소에 보관된 암호화키를 활용하여 복구할 수 있다.

부칙

제1조(시행일) 이 지침의 시행일은 대표이사가 승인한 날로 한다.

[별표]

암호화 대상 별 적용 정책

| 암호화 대상                                              | 암호화 알고리즘                   | 암호화 적용 정책 |    |         |    |
|-----------------------------------------------------|----------------------------|-----------|----|---------|----|
|                                                     |                            | 저장시 암호화   |    | 전송시 암호화 |    |
|                                                     |                            | DB        | PC | 내부      | 외부 |
| 고유식별정보(주민등록번호, 외국인등록번호, 운전면허번호, 여권번호), 국내거소신고번호, CI | 양방향(AES256)                | 필수        | 필수 | 필수      | 필수 |
| 인증정보(PIN, 비밀번호)                                     | 단방향(SHA256)                | 필수        | 불가 | 필수      | 필수 |
| 바이오정보                                               | 단방향(SHA256) 또는 양방향(AES256) | 필수        | 불가 | 필수      | 필수 |
| 카드번호, 위치정보                                          | 양방향(AES256)                | 필수        | 필수 | 필수      | 필수 |
| 개인신용정보(개인정보+ 신용정보)                                  | 양방향(AES256)                | 선택        | 필수 | 필수      | 필수 |

이름: (서명)